

Microfinance Digital Lending Platform

Domain: Microfinance & Digital Lending | Statutory Architecture

Parameter	Evaluation Result	Governance & Statutory Impact
MoSCoW Baseline	Must Have	Statutory compliance with RBI Master Directions, Aadhaar eSign Guidelines, and RBI Credit Information Clearing House (CIC) Guidelines.
Risk Classification	CRITICAL / HIGH-IMPACT (94/100)	High financial asset impact; requires automated verification gates
Total Requirements	30 Modular Requirements	Decomposed into Frontend, Backend, Auth, Security, Database, and Resilience

1. System Scope & Stakeholder Requirement Statement

"Build a microfinance digital lending app for rural dairy farmers with milk collection center integration, Aadhaar eSign, and automated daily UPI micro-debits."

2. Modular Software Requirements Specification (30 Detailed Points)

Pillar: Frontend & Mobile UI/UX (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-FE-01	Microfinance Digital Lending Platform — Intuitive User & Stakeholder Interface Provide responsive, accessible client-facing interfaces for Lending Officer, MFI Client, UPI Merchant Gateway, supporting end-to-end execution of 'Loan Application & Approval' with interactive state feedback.	Must Have	Regulation: RBI Master Direction on Digital Lending (DLDP) Acceptance: Renders complete workflow with client-side form validation and latency < 250ms.
REQ-FE-02	Multilingual Accessibility & Offline Operation Implement dynamic multilingual localization (English, Hindi, and regional Indian languages) with offline-first form persistence and sync-on-reconnect for Lending Officer, MFI Client, UPI Merchant Gateway.	Should Have	Regulation: Digital Personal Data Protection Act, 2023 (Multilingual Consent) Acceptance: Allows offline draft caching in encrypted IndexedDB; synchronizes queued records within 2 seconds of network restoration.
REQ-FE-03	Digital Document Uploader & Real-Time OCR Verification Deliver secure client-side document and KYC capture with client-side image compression, real-time edge blur detection, and instant verification feedback for Microfinance Digital Lending Platform.	Must Have	Regulation: RBI KYC Master Direction & Information Technology Act 2000 Acceptance: Validates document MIME-types and enforces 5MB payload limit; rejects blurry or glare-compromised uploads client-side.
REQ-FE-04	Interactive Audit Trail & Activity Dashboard Provide an interactive dashboard displaying real-time transaction statuses, pending approvals, and downloadable account statements for Microfinance Digital Lending Platform.	Should Have	Regulation: RBI Fair Practices Code & Customer Protection Norms Acceptance: Displays real-time transaction timeline with instant PDF statement download.

REQ-FE-05	Session Security & Device Binding UI Controls Enforce device fingerprint binding, automated background biometric re-authentication prompts, and visual privacy watermarks on all sensitive screens of Microfinance Digital Lending Platform.	Must Have	Regulation: RBI Digital Payment Security Controls Sec 4.3 Acceptance: <i>Detects emulator/root status at launch; triggers graceful lock with descriptive user guidance.</i>
-----------	--	-----------	--

Pillar: Backend Architecture & APIs (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-BE-01	Core Microservices & Switch Engine for Microfinance Digital Lending Platform Deploy modular, low-latency microservices orchestrating 'Loan Application & Approval' with transactional atomicity, idempotent request handling, and REST/gRPC API contracts.	Must Have	Regulation: RBI Master Direction on Digital Lending (DLDP) Acceptance: <i>Maintains idempotent processing with unique UUID key checks; enforces 99.95% API uptime SLA.</i>
REQ-BE-02	High-Throughput Asynchronous Event Broker Integrate an event-driven streaming pipeline (Kafka/RabbitMQ) for asynchronous notification dispatch, ledger state transitions, and audit telemetry.	Must Have	Regulation: SEBI CSCRF / RBI Cyber Security Architecture Guidelines Acceptance: <i>Processes 10,000 events/second with zero message loss and at-least-once delivery guarantees.</i>
REQ-BE-03	Automated Regulatory Telemetry & FIU-IND Reporting Pipeline Implement automated transaction monitoring generating Cash Transaction Reports (CTR) and Suspicious Transaction Reports (STR) formatted for FIU-IND FINnet 2.0 batch exports.	Must Have	Regulation: Prevention of Money Laundering Act (PMLA 2002) & FIU-IND Reporting Directives Acceptance: <i>Flags suspicious velocity or threshold anomalies (>₹10 Lakhs) within 60 seconds; exports validated XML schema batch.</i>
REQ-BE-04	External Banking Switch & Partner API Gateway Orchestrate external API integrations (NPCI, sponsor banks, credit bureaus, CKYCR) via mutual TLS (mTLS) with token-bucket rate limiting and circuit breaking.	Must Have	Regulation: RBI Guidelines on Outsourcing & Digital Lending Partner Oversight Acceptance: <i>Restricts unauthorized partner API requests; enforces 150 req/min rate limit per tenant.</i>
REQ-BE-05	Real-Time Automated Reconciliation Engine Deploy automated 2-way and 3-way reconciliation jobs matching application ledger entries against sponsor bank settlement files and NPCI clearing reports.	Must Have	Regulation: RBI Harmonisation of Turn Around Time (TAT) and Customer Compensation Acceptance: <i>Identifies discrepancies and triggers automated compensatory reversals within T+1 day.</i>

Pillar: Authentication, Identity & KYC (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-AUTH-01	RBI-Compliant Video KYC (V-CIP) & Identity Onboarding Execute automated customer identification for Lending Officer, MFI Client, UPI Merchant Gateway with live facial liveness detection, Indian geo-coordinate validation, and real-time PAN verification.	Must Have	Regulation: RBI KYC Master Direction - V-CIP Amendment Acceptance: <i>Rejects recorded spoof video attempts; verifies GPS coordinates within Indian territorial borders.</i>
REQ-AUTH-02	UIDAI Aadhaar Data Vault (ADV) & Number Masking Store 12-digit Aadhaar numbers exclusively inside an isolated Hardware Security Module (HSM) Aadhaar Data Vault (ADV), substituting database references with tokens and masking first 8 digits.	Must Have	Regulation: UIDAI Aadhaar Data Vault Circular (2017) & Masking Directive Acceptance: <i>Zero plaintext 12-digit Aadhaar numbers persist in operational application tables or logs.</i>

REQ-AUTH-03	Central KYC Registry (CKYCR) & NSDL PAN Verification Query CKYCR and NSDL databases in real time to auto-populate customer verification records with minimum 80% fuzzy name-match scoring.	Must Have	Regulation: PMLA Rules 2005 & CKYCR Operating Guidelines Acceptance: Returns active PAN status and CKYC ID within 2 seconds of query.
REQ-AUTH-04	Dynamic Two-Factor Authentication (AFA) with Device Binding Mandate Additional Factor of Authentication (AFA) binding device IMEI/MAC, registered mobile number, and transaction amount hash for all financial actions in Microfinance Digital Lending Platform.	Must Have	Regulation: RBI Master Direction on Digital Payment Security Controls Sec 4 Acceptance: Terminates active session upon hardware fingerprint mismatch; enforces 180s OTP expiration window.
REQ-AUTH-05	Role-Based Access Control (RBAC) with Maker-Checker Controls Implement fine-grained RBAC with dual-authorization maker-checker workflows for high-value actions, administrative adjustments, and compliance overrides.	Must Have	Regulation: RBI IT Governance & Cyber Security Framework Acceptance: Prohibits maker from approving own transactions; logs tamper-proof authorization signatures.

Pillar: Security & Compliance (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-SEC-01	FIPS 140-2 Level 3 HSM Field-Level Encryption Encrypt all sensitive financial PII, account credentials, and transaction secrets at rest using AES-256-GCM managed by certified Hardware Security Modules (HSM).	Must Have	Regulation: RBI Digital Payment Security Controls Sec 5.2 Acceptance: Database backups contain zero plaintext PII; cryptographic keys rotate automatically every 90 days.
REQ-SEC-02	TLS 1.3 In-Transit Transport Security & SSL Pinning Enforce TLS 1.3 with forward-secrecy cipher suites across all endpoints, combined with dynamic certificate pinning on Android and iOS client applications for Microfinance Digital Lending Platform.	Must Have	Regulation: NPCI Mobile Application Security Standards v2.4 Acceptance: Prevents MITM interception proxies from inspecting or modifying client-server payloads.
REQ-SEC-03	Immutable WORM Forensic Audit Logging Maintain tamper-proof, append-only audit logs for all administrative actions, financial transactions, and authentication events with microsecond NTP time sync, preserved for 10 years.	Must Have	Regulation: CERT-In Cyber Security Direction No. 20(3)/2022-CERT-In & PMLA Sec 12 Acceptance: Logs stored in Write-Once-Read-Many (WORM) storage; prevents update or deletion by any system administrator.
REQ-SEC-04	Web Application Firewall (WAF) & Rate Limiting Engine Protect ingress endpoints against OWASP Top 10 vulnerabilities, automated credential stuffing, and volumetric DDoS attacks via adaptive rate limiting.	Should Have	Regulation: OWASP ASVS Level 3 & RBI Cyber Security Guidelines Acceptance: Blocks SQLi, XSS, and command injection at network perimeter; returns HTTP 429 upon rate limit breach.
REQ-SEC-05	Card-on-File Tokenisation (CoFT) & Sensitive Token Lifecycle Implement token lifecycle management replacing sensitive financial identifiers with network tokens issued with explicit consent and de-tokenization controls.	Must Have	Regulation: RBI Tokenisation - Card Transactions Directive (RBI/2021-22/96) Acceptance: Persistent storage contains solely encrypted tokens; raw card/PAN numbers discarded post-authorization.

Pillar: Database & Data Residency (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
--------	--------------------------------	----------	--

REQ-DB-01	100% Sovereign On-Soil Data Localization Host all primary databases, replicas, backups, and transaction logs exclusively within physical data centers located on Indian soil with zero foreign replication.	Must Have	Regulation: RBI Storage of Payment System Data Directive (RBI/2017-18/153) Acceptance: Annual CERT-In empaneled System Audit Report (SAR) certifies 100% data residency inside Indian territory.
REQ-DB-02	ACID Financial Ledger with Double-Entry Bookkeeping Implement relational tables with serializable transaction isolation enforcing double-entry ledger bookkeeping (Sum of Debits == Sum of Credits) for Microfinance Digital Lending Platform.	Must Have	Regulation: RBI Core Banking Accounting & Audit Norms Acceptance: Eliminates floating-point rounding errors; rolls back failed atomic transactions without orphan states.
REQ-DB-03	DPDP Act 2023 Multilingual Consent Ledger & 72-Hour Data Erasure Record granular, unbundled consent timestamps and purposes in an immutable ledger, providing automated cascading data anonymization/erasure pipelines upon user revocation.	Must Have	Regulation: Digital Personal Data Protection Act, 2023 Sec 6 & Sec 12 Acceptance: Executes non-statutory data erasure within statutory 72-hour window upon customer consent withdrawal.
REQ-DB-04	Encrypted Archival & Statutory 10-Year Record Retention Orchestrate lifecycle policies archiving transactional and compliance records to cold encrypted storage with scheduled integrity verification hashes.	Must Have	Regulation: PMLA 2002 Sec 12 & Companies Act 2013 Acceptance: Archives records older than 180 days with SHA-256 verification hash; guarantees 10-year retrieval readiness.
REQ-DB-05	High-Availability Synchronous Multi-Zone Clustering (RPO < 1m, RTO < 15m) Deploy active-standby database clusters spanning multiple availability zones with automated failover guarantees achieving RPO < 1 minute and RTO < 15 minutes.	Should Have	Regulation: RBI Business Continuity Management Directive Acceptance: Primary node failure triggers automated promotion of standby replica in <90 seconds with zero data loss.

Pillar: Resilience, Scalability & DR (5 Specifications)

Req ID	Title & Detailed Specification	Priority	Statutory Citation & Acceptance Criteria
REQ-RES-01	Circuit Breaker & Graceful Degradation on Switch Gateways Incorporate Resilience4j circuit breakers across all external banking switches and microservices for Microfinance Digital Lending Platform to prevent cascading thread pool exhaustion.	Should Have	Regulation: RBI IT Disaster Recovery & Resilience Guidelines Acceptance: Switch error rate > 50% opens circuit within 5 seconds, returning cached fallback response without thread exhaustion.
REQ-RES-02	Geo-Redundant Disaster Recovery (DR) Site in Alternate Seismic Zone Establish hot/warm secondary Disaster Recovery infrastructure located in a geographically distant Indian seismic zone with biannual live failover drills.	Must Have	Regulation: SEBI CSCRF BCP/DR Mandate & RBI Cyber Security Framework Acceptance: Production workload successfully cuts over to secondary DR site within 2 hours during scheduled drill.
REQ-RES-03	Automated Failed Transaction Reversal & ₹100/Day Compensation Dispatcher Deploy automated reconciliation daemon detecting failed or timed-out transactions and issuing reversals within T+1 day, calculating mandatory statutory delay compensation.	Must Have	Regulation: RBI Harmonisation of TAT & Customer Compensation (2019) Acceptance: Issues customer refund within 24 hours of failure; automatically calculates ₹100/day compensation for delays.
REQ-RES-04	Real-Time Velocity & Anomaly Fraud Detection Engine Deploy rule-based and ML scoring pipelines evaluating transaction frequency, device changes, and geolocation anomalies to flag suspicious transactions prior to settlement.	Could Have	Regulation: RBI Master Direction on Fraud Risk Management Acceptance: Flags high-velocity anomaly within 500ms, triggering mandatory step-up authentication or analyst alert.

REQ-RES-05	Automated Stress Testing & NPCI Certification Test-Bed Harness Embed continuous performance testing pipelines simulating peak Indian festival transaction volumes (minimum 5,000 TPS) with zero message drops.	Should Have	Regulation: NPCI Operational Preparedness Guidelines & SEBI Capacity Norms Acceptance: <i>Sustains 5,000 TPS benchmark with 99th percentile response latency under 300ms.</i>
------------	--	--------------------	--

3. Regulatory & Statutory Grounding (Indian Banking Frameworks)

Framework	Enforcement Level	Statutory Directive / Citation
RBI Digital Payment Security Controls (2021)	Mandatory Statutory Enforcement	RBI Master Direction on Digital Payment Security Controls, Sections 4 & 5
NPCI Operating Guidelines & Mandate Circulars	Mandatory Statutory Enforcement	NPCI Procedural Guidelines & Circular on AutoPay Mandate Execution
RBI Sovereign Data Localization Directive (2018)	Mandatory Statutory Enforcement	RBI/2017-18/153 Storage of Payment System Data (100% Indian Data Centers)
Digital Personal Data Protection Act, 2023 (DPDP Act)	Mandatory Statutory Enforcement	DPDP Act 2023, Sections 6 (Consent), 8 (Fiduciary Obligations), 12 (Erasure)
UIDAI Aadhaar Act & Aadhaar Data Vault Regulations	Mandatory Statutory Enforcement	UIDAI Aadhaar Data Vault Circular (2017) & Masking Directive
PMLA 2002 & FIU-IND Reporting Guidelines	Mandatory Statutory Enforcement	Prevention of Money Laundering Act 2002 & FINnet 2.0 XML Reporting Formats

4. Mandatory Security & Architectural Controls

Control ID	Title & Architecture Specification	Automated Verification Method
RBI-AFA-01	Additional Factor of Authentication (AFA) & Dynamic Linking Mandatory 2FA with dynamic linking of beneficiary details, transaction amount, and 180s OTP validity.	Automated integration security suite verifying dynamic link integrity & zero-bypass enforcement.
UIDAI-ADV-02	Aadhaar Data Vault (ADV) Hardware Security Isolation 12-digit Aadhaar numbers isolated in FIPS 140-2 Level 3 HSM with 8-digit masking in logs.	CERT-In empaneled auditor inspection & regex vulnerability scanning for unmasked Aadhaar data.
RBI-LOC-03	100% Sovereign Data Localization on Indian Soil All financial messages, settlement data, and logs stored physically in Indian data centers.	Annual System Audit Report (SAR) submitted to RBI confirming zero foreign persistent copies.
DPDP-CON-04	Multilingual Consent Management & Revocation Pipeline Collect explicit, unbundled multilingual consent in 22 languages with 72h automated erasure.	Consent withdrawal test verifying immediate downstream API data processing cessation.

5. Traceability Matrix & Recommended SDLC Sprints

Req IDs	Target Sub-Module	SDLC Phase / Gate	Verification Deliverable
REQ-FE-01 - REQ-FE-05	Microfinance Digital Lending Platform — Client & Mobile App UI	Sprint 1-2 / Frontend & Intent Layer	Figma Design System & Mobile App SDK <i>Device Compatibility Matrix & UI Usability Signoff</i>
REQ-BE-01 - REQ-BE-05	Microfinance Digital Lending Platform — Core Microservices & Switch Engine	Sprint 3-4 / Transaction Core	Microservice Architecture & OpenAPI 3.0 Specs <i>Sandbox Simulator & Chaos Engineering Drill</i>
REQ-AUTH-01 - REQ-AUTH-05	Identity Security, V-CIP & Aadhaar Data Vault	Sprint 5 / Identity Security Spike	ADV HSM Key Schema & Geotagged Video Store <i>CERT-In Empaneled Red-Team Security Audit</i>
REQ-SEC-01 - REQ-SEC-05	FIPS HSM Encryption & Tokenizer	Sprint 6 / Cryptographic Core	HSM Key Hierarchy & Token Ledger <i>Cryptographic Validation & SAST/DAST Pipeline</i>
REQ-DB-01 - REQ-DB-05	Sovereign Relational Ledger & FIU-IND Reporting	Sprint 7 / Ledger & Compliance	PostgreSQL Double-Entry Schema & FINnet 2.0 Export <i>FIU-IND Batch Validator & Data Residency Audit</i>

REQ-RES-01 - REQ-RES-05	Circuit Breakers & DR Failover Site	Sprint 8 / Hardening & DR Drills	Resilience4j Config & DR Switchover Runbook <i>Active-Passive Live Switchover & Chaos Testing</i>
------------------------------------	-------------------------------------	----------------------------------	--